

Security

1. Overview

Security is a critical non-functional requirement that protects:

- Users
- Data
- Services
- Infrastructure
- Revenue
- Reputation

In system design interviews, security should be discussed for **external threats** and **internal misuse**.

2. Security Goals (CIA Triad)

Goal	Meaning
Confidentiality	Only authorized access
Integrity	Data cannot be altered improperly
Availability	System remains accessible

3. Main Areas to Cover in Interviews

Always think about:

None

Authentication

Authorization

Encryption

Network security

Abuse prevention

Secrets management

Auditability

Monitoring

4. External vs Internal Threats

External Threats

- Hackers
- Bots
- Credential stuffing
- DDoS
- API abuse
- Injection attacks

Internal Threats

- Excessive employee access
- Misconfigured permissions
- Accidental leaks
- Insider abuse
- Compromised internal service

5. Authentication

Verifies identity.

Examples:

- Username/password
- OTP
- SSO
- OAuth login
- API keys
- Service-to-service certificates

6. Authorization

Determines what user can do.

Examples:

None

User can view own profile

Admin can suspend accounts

Merchant can view own orders only

Use:

- RBAC (Role Based Access Control)
- ABAC (Attribute Based Access Control)

7. OAuth 2.0

OAuth 2.0 is commonly used for delegated access.

Example:

None

Login with Google

Allow calendar access

User grants limited access without sharing password.

8. OpenID Connect (OIDC)

OpenID Connect adds identity on top of OAuth 2.0.

Used for:

- Sign in with Google
- Enterprise SSO
- Identity tokens

9. TLS / HTTPS

Use TLS for secure communication.

Protects:

- Credentials
- Session tokens
- Personal data
- API traffic

None

HTTP 

HTTPS 

10. TLS Termination

Often done at:

- Load balancer
- API gateway
- Reverse proxy

Flow:

None

Client HTTPS → Load Balancer

LB decrypts traffic

LB forwards internally

Benefits:

- Offloads CPU cost
- Centralized cert management

11. Encryption in Transit (Internal)

Sensitive systems may also encrypt between internal services.

None

Service A ↔ Service B using mTLS

Needed when:

- Zero trust network
- Regulated data
- Shared network environments

12. mTLS (Mutual TLS)

Both sides authenticate each other.

Useful for service-to-service trust.

13. Encryption at Rest

Stored data encrypted in:

- Databases
- Object storage
- Backups
- Disks

Examples:

- DB transparent encryption
- Encrypted volumes
- Cloud KMS keys

14. Encryption vs Hashing

Different concepts.

Method	Purpose
Encryption	Recoverable with key
Hashing	One-way transformation

Use hashing for passwords.

15. Password Storage

Never store plaintext passwords.

Use:

- bcrypt
- scrypt
- Argon2

With salts.

16. Secrets Management

Never hardcode:

- API keys
- DB passwords
- JWT secrets

Use:

- Secret manager
- Vault
- Environment injection
- Key rotation

17. Rate Limiting

Important for public APIs.

Protects against:

- Abuse
- Brute force
- Scrapers
- DDoS-lite traffic spikes

Examples:

None

100 requests/min/user

10 login attempts/hour/IP

18. DDoS Protection

Use:

- CDN/WAF
- Rate limits
- Traffic scrubbing
- Autoscaling
- Bot detection

19. Input Validation

Prevent common attacks:

- SQL injection
- NoSQL injection
- XSS
- Command injection
- Path traversal

Use:

- Parameterized queries
- Escaping
- Allowlists
- Sanitization

20. Session Security

Use:

- Secure cookies
- HttpOnly cookies
- SameSite settings
- Token expiry

- Refresh token rotation

21. Principle of Least Privilege

Every user/service gets minimum required permissions.

Bad:

None

All services = admin access

Good:

None

Order service can only access order DB

22. Network Segmentation

Separate internal zones:

- Public web tier
- App tier
- DB tier
- Admin network

Reduces blast radius.

23. Logging and Auditing

Track:

- Login attempts
- Permission changes
- Sensitive data access
- Failed auth
- Admin actions

Needed for forensics and compliance.

24. Security Monitoring

Detect:

- Traffic spikes
- Suspicious IPs
- Token misuse
- Repeated failed logins
- Data exfiltration patterns

25. Data Privacy Minimization

Store only necessary data.

Examples:

- Don't store full card data unless needed
- Mask PII in logs
- Delete stale data

26. Backup Security

Backups must also be:

- Encrypted
- Access controlled
- Audited

Many systems secure prod DB but forget backups.

27. Common Interview Example: E-commerce

Need:

- HTTPS everywhere
- Payment tokenization
- RBAC for admin panel
- Fraud/rate limiting
- Audit logs
- Encrypted user data

28. Common Security Mistakes

Open S3 buckets
Hardcoded secrets
No rate limiting
Plaintext passwords
Shared admin accounts
Excessive permissions
Missing patching

29. Interview Answer Framework

When asked security, say:

I'd secure authentication and authorization, enforce TLS, encrypt sensitive data at rest, manage secrets centrally, add rate limiting/WAF, log privileged actions, and apply least privilege across services.

30. Trade-off Table

Decision	More Secure	Simpler/Faster
End-to-end encryption	Yes	More overhead
TLS termination only	Simpler	Less internal protection
Strict RBAC	Yes	More admin work

Open internal network	Easier	Riskier
Short token expiry	Safer	More refreshes

31. Best Practices

- Security by design, not later
- Assume breach mindset
- Rotate keys regularly
- Patch dependencies
- Automate scans
- Limit access
- Monitor continuously
- Test incident response

32. Short Revision Notes

None

Security = Protect data/services/users

Must discuss:

- AuthN
- AuthZ
- TLS
- Encryption at rest
- Secrets
- Rate limiting
- Logging
- Least privilege